Al al-Bayt University - Prince Al Hussein bin Abdullah II Faculty of Information Technology

Course Information and Database Security (906313)
First Semester 2026/2027 - Final Semester Project

# SecARS

Secure Academic Records System

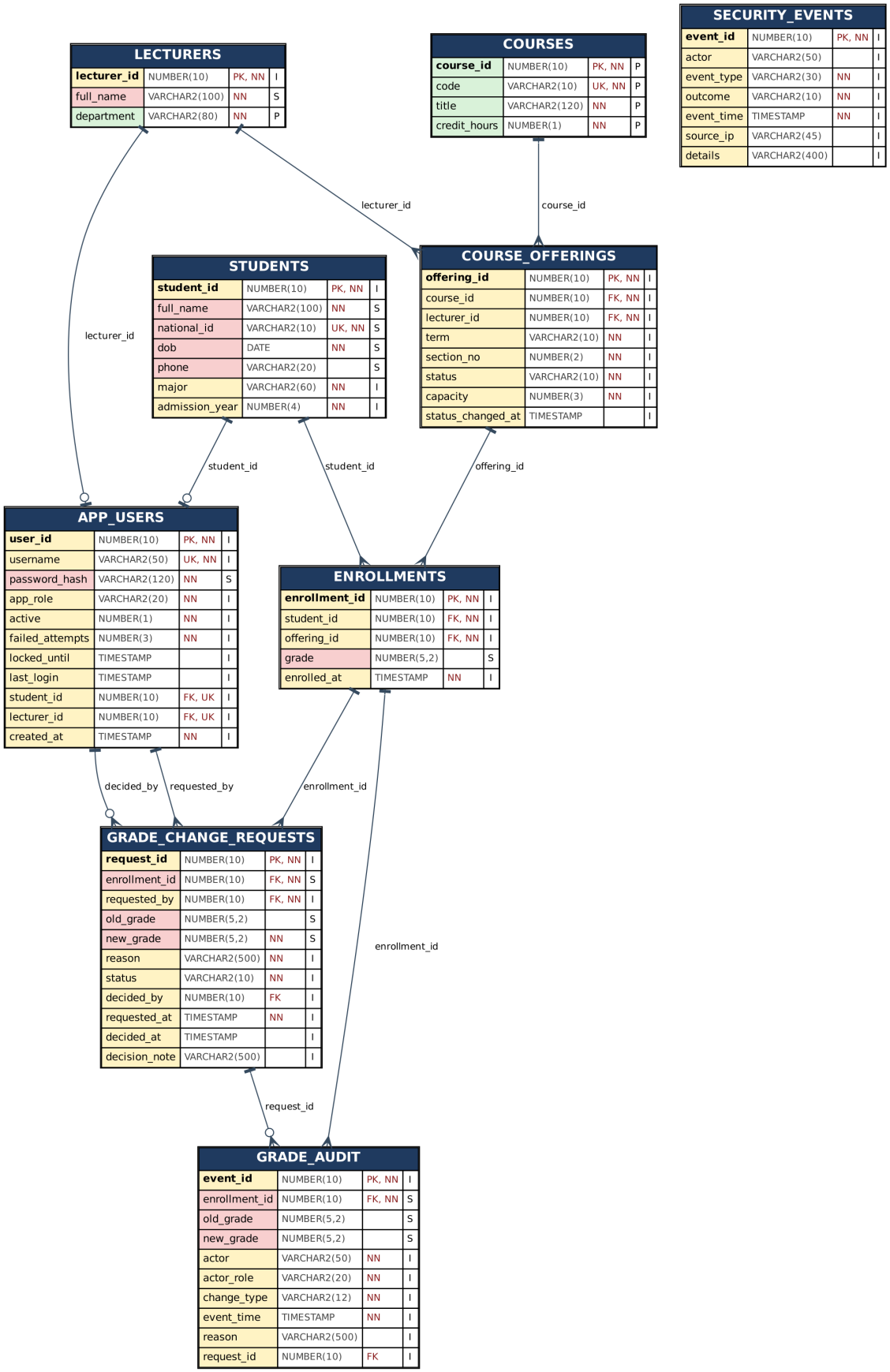
## Entity-Relationship Diagram and Data Dictionary

Tables, fields, data types, keys, relationships, constraints and data classification

**Group members**
Abdullah Ibrahim Hassan
Abdulrahman Al-Otaibi

Milestone M1 - Analysis & Design | Due Friday 06/11/2026
Version 1.0 | November 2026

# 1. ERD - SecARS database (schema ARS_OWNER)




*Legend: PK primary key, FK foreign key, UK unique, NN not null. Last column = data classification: **P** Public (green), **I** Internal (yellow), **S** Sensitive (red). Crow's foot = many side, circle = optional. No foreign key uses ON DELETE CASCADE.*

# 2. Overview and design decisions

- Nine tables, all owned by ARS_OWNER. The service account APP_USER owns nothing and has no direct privilege on any table (SR03).
- APP_USERS is separate from STUDENTS and LECTURERS: a login is linked to an academic identity by student_id / lecturer_id, protected by the CHECK ck_user_identity. Registrar and auditor accounts link to nobody.
- Grades live in ENROLLMENTS.grade. The row identifies both student and section, so one VPD policy on ENROLLMENTS can restrict students to their own PUBLISHED rows and lecturers to their own sections.
- COURSE_OFFERINGS.status (OPEN, SUBMITTED, PUBLISHED) is the grade-entry state machine of the specification.
- GRADE_CHANGE_REQUESTS stores the post-closure workflow (FR06). The CHECK decided_by <> requested_by enforces the four-eyes rule in the database, not only in code.
- GRADE_AUDIT stores actor and role as text snapshots (not foreign keys) so history cannot change if an account is later disabled or renamed. It is append-only: written by trigger/ARS_API, no UPDATE/DELETE for APP_USER or any role.
- SECURITY_EVENTS deliberately has no foreign key to APP_USERS, because failed logins with unknown usernames must also be recorded.
- Every foreign key uses the default NO ACTION, so a student, section or account that is still referenced cannot be deleted by mistake (BR15).

## 2.1 Relationships

| Parent (1) | Child | FK column | Cardinality | On delete |
|---|---|---|---|---|
| STUDENTS | APP_USERS | student_id | 1 : 0..1 | NO ACTION |
| LECTURERS | APP_USERS | lecturer_id | 1 : 0..1 | NO ACTION |
| COURSES | COURSE_OFFERINGS | course_id | 1 : N | NO ACTION |
| LECTURERS | COURSE_OFFERINGS | lecturer_id | 1 : N | NO ACTION |
| STUDENTS | ENROLLMENTS | student_id | 1 : N | NO ACTION |
| COURSE_OFFERINGS | ENROLLMENTS | offering_id | 1 : N | NO ACTION |
| ENROLLMENTS | GRADE_CHANGE_REQUESTS | enrollment_id | 1 : N | NO ACTION |
| APP_USERS | GRADE_CHANGE_REQUESTS | requested_by | 1 : N | NO ACTION |
| APP_USERS | GRADE_CHANGE_REQUESTS | decided_by | 1 : 0..N | NO ACTION |
| ENROLLMENTS | GRADE_AUDIT | enrollment_id | 1 : N | NO ACTION |
| GRADE_CHANGE_REQUESTS | GRADE_AUDIT | request_id | 1 : 0..N | NO ACTION |

# 3. Data dictionary

## APP_USERS

*Application login accounts; one row per person who can sign in. Linked to exactly one academic identity (student or lecturer) or to none (registrar, auditor).*

| Column | Data type | Keys / constraints | Class | Note |
|---|---|---|---|---|
| **user_id** | NUMBER(10) | PK, identity | Internal | Surrogate key |
| **username** | VARCHAR2(50) | UK, NOT NULL | Internal | Login name; unique |
| **password_hash** | VARCHAR2(120) | NOT NULL | Sensitive | BCrypt/Argon2 hash only; never the password |
| **app_role** | VARCHAR2(20) | NOT NULL, CHECK IN (STUDENT, LECTURER, REGISTRAR, AUDITOR) | Internal | Role is read from here, never from the client |
| **active** | NUMBER(1) | NOT NULL, DEFAULT 1, CHECK IN (0,1) | Internal | 0 = disabled account, login refused |
| **failed_attempts** | NUMBER(3) | NOT NULL, DEFAULT 0 | Internal | Consecutive failed logins (lockout counter) |
| **locked_until** | TIMESTAMP | NULL | Internal | Temporary lockout expiry |
| **last_login** | TIMESTAMP | NULL | Internal | Last successful login |
| **student_id** | NUMBER(10) | FK -> STUDENTS, UK, NULL | Internal | Set only when app_role = STUDENT |
| **lecturer_id** | NUMBER(10) | FK -> LECTURERS, UK, NULL | Internal | Set only when app_role = LECTURER |
| **created_at** | TIMESTAMP | NOT NULL, DEFAULT SYSTIMESTAMP | Internal | Account creation time |
| **table check** | | ck_user_identity: (app_role='STUDENT' AND student_id IS NOT NULL AND lecturer_id IS NULL) OR (app_role='LECTURER' AND lecturer_id IS NOT NULL AND student_id IS NULL) OR (app_role IN ('REGISTRAR','AUDITOR') AND student_id IS NULL AND lecturer_id IS NULL) | | |

## STUDENTS

*Fictional student records. national_id, dob and phone are the protected fields (FGA on national_id, masked in the restored copy).*

| Column | Data type | Keys / constraints | Class | Note |
|---|---|---|---|---|
| **student_id** | NUMBER(10) | PK, identity | Internal | Surrogate key |
| **full_name** | VARCHAR2(100) | NOT NULL | Sensitive | PII; masked in test copy (SR12) |
| **national_id** | VARCHAR2(10) | UK, NOT NULL, CHECK REGEXP_LIKE '^[0-9]{10}$' | Sensitive | Fictional 10-digit ID; FGA-audited column |
| **dob** | DATE | NOT NULL | Sensitive | Date of birth |
| **phone** | VARCHAR2(20) | NULL | Sensitive | Masked in test copy (SR12) |
| **major** | VARCHAR2(60) | NOT NULL | Internal | Study programme |
| **admission_year** | NUMBER(4) | NOT NULL, CHECK BETWEEN 2015 AND 2030 | Internal | Year of admission |

## LECTURERS

*Fictional academic staff. Each lecturer has one login account (APP_USERS.lecturer_id).*

| Column | Data type | Keys / constraints | Class | Note |
|---|---|---|---|---|
| **lecturer_id** | NUMBER(10) | PK, identity | Internal | Surrogate key |
| **full_name** | VARCHAR2(100) | NOT NULL | Sensitive | PII; masked in test copy (SR12) |
| **department** | VARCHAR2(80) | NOT NULL | Public | Department name |

## COURSES

*Course catalogue (public information).*

| Column | Data type | Keys / constraints | Class | Note |
|---|---|---|---|---|
| **course_id** | NUMBER(10) | PK, identity | Public | Surrogate key |
| **code** | VARCHAR2(10) | UK, NOT NULL | Public | Course code |
| **title** | VARCHAR2(120) | NOT NULL | Public | Course title |
| **credit_hours** | NUMBER(1) | NOT NULL, CHECK BETWEEN 1 AND 4 | Public | Valid credit hours |

## COURSE_OFFERINGS

*A course section taught by one lecturer in one term; carries the grade-entry status that drives the grade workflow.*

| Column | Data type | Keys / constraints | Class | Note |
|---|---|---|---|---|
| **offering_id** | NUMBER(10) | PK, identity | Internal | Surrogate key |
| **course_id** | NUMBER(10) | FK -> COURSES, NOT NULL | Internal | Which course |
| **lecturer_id** | NUMBER(10) | FK -> LECTURERS, NOT NULL | Internal | Owner of the section (grade-entry right) |
| **term** | VARCHAR2(10) | NOT NULL | Internal | e.g. 2026-1 |
| **section_no** | NUMBER(2) | NOT NULL, CHECK > 0 | Internal | Section number within course/term |
| **status** | VARCHAR2(10) | NOT NULL, DEFAULT 'OPEN', CHECK IN (OPEN, SUBMITTED, PUBLISHED) | Internal | Grade-entry lifecycle |
| **capacity** | NUMBER(3) | NOT NULL, DEFAULT 40, CHECK > 0 | Internal | Maximum enrolments |
| **status_changed_at** | TIMESTAMP | NULL | Internal | Last status transition |
| **table check** | | uq_offering: UNIQUE (course_id, term, section_no) | | |

## ENROLLMENTS

*A student's registration in a section, and the grade for it. Grades are protected by VPD and can change only through ARS_API.*

| Column | Data type | Keys / constraints | Class | Note |
|---|---|---|---|---|
| **enrollment_id** | NUMBER(10) | PK, identity | Internal | Surrogate key |
| **student_id** | NUMBER(10) | FK -> STUDENTS, NOT NULL | Internal | Which student |
| **offering_id** | NUMBER(10) | FK -> COURSE_OFFERINGS, NOT NULL | Internal | Which section |
| **grade** | NUMBER(5,2) | NULL, CHECK BETWEEN 0 AND 100 | Sensitive | NULL until entered; visible to student only after PUBLISHED |
| **enrolled_at** | TIMESTAMP | NOT NULL, DEFAULT SYSTIMESTAMP | Internal | Registration time |
| **table check** | | uq_enrollment: UNIQUE (student_id, offering_id) | | |

## GRADE_CHANGE_REQUESTS

*Workflow record for changing a grade after entry is closed (FR06): one registrar requests with a reason, a different registrar approves or rejects.*

| Column | Data type | Keys / constraints | Class | Note |
|---|---|---|---|---|
| **request_id** | NUMBER(10) | PK, identity | Internal | Surrogate key |
| **enrollment_id** | NUMBER(10) | FK -> ENROLLMENTS, NOT NULL | Sensitive | Target record |
| **requested_by** | NUMBER(10) | FK -> APP_USERS, NOT NULL | Internal | Requesting registrar |
| **old_grade** | NUMBER(5,2) | NULL, CHECK BETWEEN 0 AND 100 | Sensitive | Grade at request time |
| **new_grade** | NUMBER(5,2) | NOT NULL, CHECK BETWEEN 0 AND 100 | Sensitive | Proposed grade |
| **reason** | VARCHAR2(500) | NOT NULL, CHECK LENGTH(TRIM(reason)) >= 10 | Internal | Mandatory justification |
| **status** | VARCHAR2(10) | NOT NULL, DEFAULT 'PENDING', CHECK IN (PENDING, APPROVED, REJECTED) | Internal | Workflow state |
| **decided_by** | NUMBER(10) | FK -> APP_USERS, NULL | Internal | Approving/rejecting registrar |
| **requested_at** | TIMESTAMP | NOT NULL, DEFAULT SYSTIMESTAMP | Internal | Request time |
| **decided_at** | TIMESTAMP | NULL | Internal | Decision time |
| **decision_note** | VARCHAR2(500) | NULL | Internal | Optional note |
| **table check** | | ck_sod: decided_by IS NULL OR decided_by <> requested_by (four-eyes rule, SR08) | | |
| **table check** | | ck_decision: (status='PENDING' AND decided_by IS NULL AND decided_at IS NULL) OR (status<>'PENDING' AND decided_by IS NOT NULL AND decided_at IS NOT NULL) | | |

## GRADE_AUDIT

*Immutable log of every grade change. Written only by a trigger / ARS_API inside the owner schema; neither APP_USER nor any application role has UPDATE or DELETE on it.*

| Column | Data type | Keys / constraints | Class | Note |
|---|---|---|---|---|
| **event_id** | NUMBER(10) | PK, identity | Internal | Surrogate key |
| **enrollment_id** | NUMBER(10) | FK -> ENROLLMENTS, NOT NULL | Sensitive | Target record |
| **old_grade** | NUMBER(5,2) | NULL | Sensitive | Value before the change |
| **new_grade** | NUMBER(5,2) | NULL | Sensitive | Value after the change |
| **actor** | VARCHAR2(50) | NOT NULL | Internal | Real end-user name from the verified session context (text snapshot, not FK) |
| **actor_role** | VARCHAR2(20) | NOT NULL | Internal | Role at the time of the change |
| **change_type** | VARCHAR2(12) | NOT NULL, CHECK IN (ENTRY, EDIT, POST_CLOSE) | Internal | ENTRY / EDIT while OPEN / POST_CLOSE via workflow |
| **event_time** | TIMESTAMP | NOT NULL, DEFAULT SYSTIMESTAMP | Internal | When it happened |
| **reason** | VARCHAR2(500) | NULL; NOT NULL when change_type = POST_CLOSE | Internal | Justification |
| **request_id** | NUMBER(10) | FK -> GRADE_CHANGE_REQUESTS, NULL | Internal | Approved request (POST_CLOSE only) |
| **table check** | | ck_audit_reason: change_type <> 'POST_CLOSE' OR (reason IS NOT NULL AND request_id IS NOT NULL) | | |

## SECURITY_EVENTS

*Security log: failed logins, lockouts, denied access, IDOR attempts. Readable by the auditor role only. No FK to APP_USERS on purpose: attempts with unknown usernames must also be recorded.*

| Column | Data type | Keys / constraints | Class | Note |
|---|---|---|---|---|
| **event_id** | NUMBER(10) | PK, identity | Internal | Surrogate key |
| **actor** | VARCHAR2(50) | NULL | Internal | Username (claimed or verified) |
| **event_type** | VARCHAR2(30) | NOT NULL | Internal | LOGIN_FAILED, ACCOUNT_LOCKED, ACCESS_DENIED, IDOR_BLOCKED, ... |
| **outcome** | VARCHAR2(10) | NOT NULL, CHECK IN (SUCCESS, DENIED, FAILURE) | Internal | Result |
| **event_time** | TIMESTAMP | NOT NULL, DEFAULT SYSTIMESTAMP | Internal | When |
| **source_ip** | VARCHAR2(45) | NULL | Internal | Client address |
| **details** | VARCHAR2(400) | NULL | Internal | Sanitised detail; never passwords or tokens |

# 4. Data-classification chart

**Public** = may be shown to anyone who can reach the application. **Internal** = needed for operation, shown only to authenticated roles that need it. **Sensitive** = personal data, credentials and grades: restricted by role/VPD, audited, masked in test copies, and excluded from the auditor reports.

| Table | Public | Internal | Sensitive | Protection of the sensitive fields |
|---|---|---|---|---|
| **APP_USERS** | - | user_id, username, app_role, active, failed_attempts, locked_until, last_login, student_id, lecturer_id, created_at | password_hash | Hash only (BCrypt/Argon2); never returned by any API; no SELECT for APP_USER |
| **STUDENTS** | - | student_id, major, admission_year | full_name, national_id, dob, phone | ARS_API returns national_id/dob/phone to the registrar only; FGA on national_id; masked in restored copy |
| **LECTURERS** | department | lecturer_id | full_name | Name masked in restored copy; not shown to students beyond section view |
| **COURSES** | course_id, code, title, credit_hours | - | - | (none - public catalogue) |
| **COURSE_OFFERINGS** | - | offering_id, course_id, lecturer_id, term, section_no, status, capacity, status_changed_at | - | (none) |
| **ENROLLMENTS** | - | enrollment_id, student_id, offering_id, enrolled_at | grade | grade: VPD + status = PUBLISHED for students; entry rules in ARS_API |
| **GRADE_CHANGE_REQUESTS** | - | request_id, requested_by, reason, status, decided_by, requested_at, decided_at, decision_note | enrollment_id, old_grade, new_grade | Registrar and auditor only; four-eyes rule |
| **GRADE_AUDIT** | - | event_id, actor, actor_role, change_type, event_time, reason, request_id | enrollment_id, old_grade, new_grade | Auditor read-only; append-only; old/new grade values sensitive |
| **SECURITY_EVENTS** | - | event_id, actor, event_type, outcome, event_time, source_ip, details | - | (none sensitive; contains no passwords or tokens) |

# 5. Rules enforced by triggers and ARS_API (not expressible as column constraints)

| Rule | Mechanism (implemented in M2/M3) |
|---|---|
| **Every change of ENROLLMENTS.grade writes GRADE_AUDIT with real actor, old/new value, time, reason** | Compound/row trigger plus ARS_API; actor read from the trusted context ARS_CTX (SR07) |
| **Direct grade edit only when the section is OPEN and owned by the caller** | ARS_API check + VPD policy on ENROLLMENTS (SR04) |
| **Capacity of a section is not exceeded** | ARS_API check before insert into ENROLLMENTS (BR09) |
| **Status moves only OPEN -> SUBMITTED -> PUBLISHED** | ARS_API procedures set_status; no other path to update status |
| **Audit tables cannot be changed by application roles** | No INSERT/UPDATE/DELETE grants to APP_USER; trigger/package in owner schema is the only writer; Unified Audit on DML |